# PlantPal+ Test Execution Report

Tester: Alvin . Report date: 21 October 2026.

## 1. Summary

- Automated: 849 new tests (RUN-01 805, RUN-01B 44). RUN-02 re-ran all 849 on the tester's machine: 813 pass, 36 fail. Every failure carries a [DEF-nnn] tag and proves a logged defect. Zero unexplained failures.
- Manual: 57 Must-priority cases executed, 30 pass, 27 fail.
- Defects: 48 defects raised (DEF-012 withdrawn, not counted). Three S2 defects remain open: DEF-005, DEF-008, DEF-019.

## 2. Scope and environment

In scope: unit, component, API integration and white-box tests of shared, web, mobile (logic), and api; local-API latency; dependency audit and secret scan; manual Must-priority demonstration, inspection, security, compliance and UAT rows executed against a local build.

Environments:

| Run | Environment |
|---|---|
| Baseline (existing suite) | Sandbox, Ubuntu 24, Node 22.22, PostgreSQL 16, Vitest 4.1.10 |
| RUN-01, RUN-01B | Same sandbox, 18 Oct 2026 |
| RUN-02 | Windows, Node 24.21.0, PostgreSQL 16, Vitest 4.x, 18 Oct 2026 |
| Manual (curl, code review) | Local API :4000, sandbox, 19 Oct 2026 |
| Manual (browser) | Headless Chromium via Playwright against local build :5173, 21 Oct 2026 |
| Manual (UAT) | Local build, 19 Oct 2026 |

# 3. Automated results

| Run | Tests | Pass | Fail | Notes |
|---|---|---|---|---|
| Baseline (existing suite, with PostgreSQL) | 466 | 466 | 0 | shared 53, api 239, web 150, mobile 24 |
| RUN-01 | 805 | 775 | 30 | shared 260 (4 fail), web 47 (1), mobile 33 (0), api 465 (25) |
| RUN-01B | 44 | 38 | 6 | expoPush 10, FitnessPage 6, PlantsPage 9, NutritionPage 6, known-gaps integration 13 |
| New total (RUN-01 + 01B) | 849 | 813 | 36 | All 36 failures tagged [DEF-nnn] |
| RUN-02 (tester) | 849 | 813 | 36 | Same 36 failures as RUN-01 and RUN-01B |

Notes on RUN-02: the first API attempt ran test files in parallel against one database and produced 68 failures, 38 untagged. Cause: the harness cleanup deletes every @verify.plantpal.example user, which removes rows another file is still using (foreign-key errors). Re-run serially, the result matches RUN-01. This is a test-isolation limit, not an application defect. Integration suites skip without TEST_DATABASE_URL, and a skip is not a pass.

The 36 failing tests prove DEF-001 to DEF-011 and DEF-013 to DEF-021. DEF-022 (dependency audit) has no test.

## Coverage (v8, existing plus new tests, files the tests load)

| Package | Lines | Branches | Functions |
|---|---|---|---|
| api | 87.0% | 78.9% | 86.0% |
| shared | 100% | 100% | n/a |

The shared figure counts only files the tests load; it is not a whole-package number.

### Performance (local API, loopback, 150 samples per scenario, small dataset)

All 7 scenarios pass with wide margin: read p95 3 to 5 ms (limit 400 ms), dashboard p95 7 ms (limit 800 ms), writes p95 7 to 10 ms (limit 600 ms). This shows the server code is not slow; it does not prove the deployed system meets NFR-PERF.

### Security (automated)

Passing: JWT forgery cases (wrong secret, alg=none, expiry, audience, issuer, signature flip), refresh rotation and reuse revocation as tested in the suite, CSRF origin check, IDOR across every plant route, 34 routes returning 401 anonymously, enumeration resistance and timing floor, security headers, CORS, body-size handling (except DEF-016), SQL metacharacters, error leakage, rate limiting.

Dependency audit (`npm audit --omit=dev`, 18 Oct 2026): 35 findings (2 critical, 23 high, 10 moderate), logged as DEF-022. Triage: one critical finding is on the API runtime path (proxy-addr via express 4.22.2, with trust proxy set to 1, so req.ip and anything keyed on it, such as rate limiting, can be affected; a non-major fix exists). The other 24 critical/high findings sit in the mobile Expo/Metro build tooling and are probably not shipped, which is a judgement, not proven. Do not apply npm's suggested fix (expo@44.0.6, a downgrade artefact). Proposed handling: DEF-022a (proxy-addr, S3, fix and retest rate limiting) and DEF-022b (mobile toolchain, S4 until shown to ship).

Secret scan: regex heuristic over the repository outside tests, docs and examples found nothing. This is not gitleaks.

## 4. Requirement traceability

89 functional requirements are mapped to at least one automated test.

## 5. Manual test results

57 Must-priority cases executed, counted from the checklist rows.

| Area | Pass | Fail |
|---|---|---|
| Demonstration (FR-derived) | 1 | 13 |
| Inspection (code review) | 3 | 7 |
| Security (manual) | 7 | 1 |

| Area | Pass | Fail |
|---|---|---|
| Compliance | 5 | 5 |
| UAT (tester) | 14 | 1 |
| **Total** | **30** | **27** |

Passes worth stating: IDOR replay returns 404 for user B on GET, PUT and DELETE; logout invalidates the refresh token; stored XSS payloads render as text; CSRF on cookie refresh returns 403; login lockout returns 429 with Retry-After on the 6th failure; no secrets in browser storage; error pages leak no stack trace or path; age gate refuses registration without confirmed_age (422); analytics opt-in defaults to off; deletion request, grace period, cancel and post-grace purge work end to end; deletion is reachable in 2 taps. UAT: 14 of 15 pass (see MT-UAT-004 below).

## 6. Defects

48 defects raised. DEF-012 withdrawn. DEF-001 to DEF-022 are in the workbook `Defect_Log`; DEF-023 to DEF-059 come from the manual checklist and are not yet merged into the workbook. Severities for DEF-023 to DEF-037 are not recorded in the source files.

### 6.1 Automated-test defects (DEF-001 to DEF-022)

| ID | Title | Sev |
|---|---|---|
| DEF-001 | roundHalfUp returns -0 for values in (-0.5, 0) | S4 |
| DEF-002 | SRS inconsistent on minimum age: BR-NUT-11 says 13..120, BR-ACC-13 closed it at 16 | S4 |
| DEF-003 | totalVolumeKg does no validation; setVolumeKg does | S3 |
| DEF-004 | Impossible calendar dates accepted by streak logic | S3 |
| DEF-005 | Password policy BR-ACC-01 clauses 3, 4, 5 not enforced | S2 |
| DEF-006 | Pot diameter 0 or negative accepted on plant create | S3 |

| ID | Title | Sev |
|---|---|---|
| DEF-007 | Daily growth-entry limit (5 per plant per local date) not enforced | S3 |
| DEF-008 | Plant schedule not computed at creation or recomputed on edit | S2 |
| DEF-009 | Malformed or impossible calendar dates not rejected with 422 | S3 |
| DEF-010 | Client-supplied calories_burned overrides server computation | S3 |
| DEF-011 | Negative or fractional reps, negative or non-numeric weight return 500 | S3 |
| DEF-013 | Online idempotent replay returns 409 instead of 200 with Idempotent-Replay | S3 |
| DEF-014 | Sync WORKOUT body mass limit 400 kg vs online and SRS limit 635 kg | S3 |
| DEF-015 | Settings accept an invalid IANA timezone | S3 |
| DEF-016 | Request body over 1 MB returns 500 instead of 413 | S3 |
| DEF-017 | Care history of another user's or a missing plant returns 200 [] not 404 | S4 |
| DEF-018 | Growth photos are links, not uploads: POST /media/uploads and /media/{id}/finalize return 404 (FR-SYS-11) | S3 |
| DEF-019 | Account erasure sends no email and clears no object storage (database erasure itself passes) | S2 |
| DEF-020 | Queued write from an erased account returns 422 VALIDATION_FAILED, not 410 ACC_ACCOUNT_DELETED | S4, proposed S3 |
| DEF-021 | Reminder time parser reads a minute value of 60 or more as the next hour | S4 |
| DEF-022 | npm audit: 2 critical, 23 high in production dependencies (split into 022a S3, 022b S4 proposed) | S3 |

DEF-008, 013 and 015 depend on the tester's reading of the SRS and API spec. DEF-006's effect on scheduling is inferred.

## 6.2 Manual inspection, security, compliance and UAT defects (DEF-023 to DEF-037)

| ID | Title | Source row |
|---|---|---|
| DEF-023 | No personal record created after a strength workout (nothing inserts into personal_records); volume 1500 kg and 1RM 116.7 kg are correct | MT-UAT-004 (tester-reported, cause by code review) |
| DEF-024 | No language placeholder or i18n readiness (FR-SET-25) | MT-INS-002 |
| DEF-025 | Activity-type catalogue exists only as a CHECK constraint, not a seeded catalogue (FR-FIT-01) | MT-INS-003 |
| DEF-026 | Strength-exercise catalogue below the SRS minimum (20 seeded) (FR-FIT-11) | MT-INS-004 |
| DEF-028 | Achievement catalogue seeds 16, SRS requires 46 (FR-GAM-11) | MT-INS-007 |
| DEF-029 | Food catalogue below the SRS minimum (180 seeded) (FR-NUT-07) | MT-INS-008 |
| DEF-030 | API surface conventions and request identity not fully met (FR-SYS-18) | MT-INS-010 |
| DEF-031 | No sync_seq or tz_at_capture on any table (FR-SYS-22) | MT-INS-011 |
| DEF-032 | No privacy notice or terms link on the registration page | MT-CMP-001 |
| DEF-033 | consent_records empty (0 rows) after registering 5 accounts | MT-CMP-002 |
| DEF-034 | No data export route (account/export, account/data-export, sync/export all missing) | MT-CMP-004 |

| ID | Title | Source row |
|---|---|---|
| DEF-035 | Health "not medical advice" disclaimer only on landing and auth layouts, absent on fitness and nutrition screens | MT-CMP-007 |
| DEF-036 | No in-app licences page matching THIRD_PARTY_LICENSES.md | MT-CMP-010 |
| DEF-037 | Previous (already rotated) refresh token is still accepted (200); reuse after rotation not rejected. Logged against MT-SEC-002, whose own check (post-logout reuse returns 401) passed | MT-SEC-002 |

DEF-037 conflicts with the RUN-01 automated claim that refresh-reuse revocation passes. The two have not been reconciled: re-test on the tester's machine before relying on either.

## 6.3 Demonstration defects (DEF-038 to DEF-059)

All raised from headless browser or code-level demonstration rows. Each is logged as raised and should be re-checked by hand.

| ID | Title | FR | Pri | Sev |
|---|---|---|---|---|
| DEF-038 | Onboarding progress not recorded or resumed (wizard restarts at step 1 on reload; no API route reads or writes it) | FR-ACC-17 | Must | S3 |
| DEF-039 | Quick-add action set absent from dashboard | FR-DSH-10 | Must | S3 |
| DEF-040 | No date navigation or Today control on dashboard | FR-DSH-12 | Must | S3 |
| DEF-041 | Empty and all-caught-up states not as specified | FR-DSH-16 | Must | S3 |
| DEF-043 | Below 768 px stat and module cards show two columns, requirement is one (Tailwind sm: starts at 640 px) | FR-DSH-22 | Must | S3 |
| DEF-044 | Settings is one scrolling page, not the specified hub | FR-SET-01 | Must | S3 |

| ID | Title | FR | Pri | Sev |
|---|---|---|---|---|
| DEF-045 | No profile entry point in Settings | FR-SET-02 | Must | S3 |
| DEF-048 | Workout energy shown as ~515 kcal with no error band, range or non-medical disclaimer | FR-FIT-06 | Must | S3 |
| DEF-049 | Unlock gives only a generic toast, not the specified unlock experience | FR-GAM-16 | Must | S3 |
| DEF-050 | Achievements page lists the 16 seeded badges without the specified trophy gallery | FR-GAM-17 | Must | S3 |
| DEF-051 | Push message carries data only, no deep link | FR-NOT-19 | Must | S3 |
| DEF-058 | Web offline: error toast only, no SYNCED/PENDING/SYNCING/FAILED states and no Needs-attention queue (mobile queue not exercised) | FR-SYS-06 | Must | S3 |
| DEF-059 | Web offline: Add plant stays enabled with no inline reason and no Try again | FR-SYS-07 | Must | S3 |

### 6.4 Open defects by severity

- S2 (3): DEF-005, DEF-008, DEF-019.
- S3 and S4: DEF-001 to DEF-022 per table above (S3 thirteen, S4 five, excluding S2 and the withdrawn DEF-012); DEF-038 to DEF-059 as tabled (13 Must at S3); DEF-023 to DEF-037 without recorded severity.

## 7. Corrections and reconciliations

- DEF-009: the earlier log said GET /dashboard?date=2026-13-45 returns 200. In the sandbox it returned 422 (database date error mapped). Re-check the dashboard row on the tester's machine.
- DEF-020: worse than logged. The response is 422 VALIDATION_FAILED with details field user_id and issue unknown_reference (a sync_events foreign-key violation). That leaks a schema field name and gives a non-terminal code, so the client will not purge its outbox and tokens as the spec requires. Spec: 410 ACC_ACCOUNT_DELETED. Severity raised from S4 to S3 is proposed.
- DEF-037 versus the automated refresh-reuse test: unreconciled, see section 6.2.

- Page tests use mocked APIs. They prove UI behaviour, not integration.
- Baseline note: the existing suite is 448 pass and 18 skipped without PostgreSQL.

## 8. Conventions

IDs: automated TC-module-nnn, manual MT-area-nnn, defects DEF-nnn. A test titled [DEF-nnn] fails on purpose until its defect is fixed. A failure without a [DEF- tag is a new finding or a test bug. RUN-01 and RUN-01B rows are never edited; retests are new rows. Evidence for manual rows is named id_RESULT_date and held in evidence_2026-10-21.zip.